

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (NVD CVSS-weighted) · Generated 2026-06-12 · Source SHA: 61ed8c3140d76e3a19a88954e834d39c9f7635fb · Model: $0.5 \cdot \text{CVE} + 0.3 \cdot \text{exposure} + 0.2 \cdot \text{criticality}$

Scoring methodology

Each dependency receives three component scores (0-10):

- **CVE Severity** — maximum CVSS base score across all CVEs, plus a density bonus of +0.5 per additional CVE beyond the first (capped at 10). Source: OWASP Dependency-Check scanner-reported scores; NVD fallback only for unscored CVEs.
- **Exposure** — reachability and blast surface: direct vs. transitive, compile/runtime vs. test, module spread, network/parsing library classification.
- **Business Criticality** — consuming code context inferred by grepping codebase imports and class names. Defaults to 2 when usage cannot be located.

Final score: $\text{risk_score} = \text{round}(0.5 \times \text{cve_severity} + 0.3 \times \text{exposure} + 0.2 \times \text{business_criticality}, 1)$

Band	Score range
CRITICAL	≥ 8.0
HIGH	6.0 - 7.9
MEDIUM	3.0 - 5.9
LOW	< 3.0

Any dependency with a CRITICAL CVE is floored at band HIGH regardless of weighted score. Supply-chain CRITICAL items (typosquat, malicious coordinate) are elevated to CRITICAL band regardless of numeric score.

Ranked remediation backlog

#	Coordinate	Ver	Band	Risk Score	CVE Score	Exposure	Criticality
1	org.apache.logging.log4j:log4j-core	2.14.1	CRITICAL	8.4	10.0	8.0	5.0
2	org.apache.logging.log4j:log4j-api	2.14.1	CRITICAL	8.4	10.0	8.0	5.0
3	com.fasterxml.jackson.core:jackson-databind	2.9.8	HIGH	7.8	10.0	8.0	2.0
4	com.fastxml.jackson.core:jackson-databind	2.9.8	CRITICAL	—	—	—	—
5	com.google.guava:guava	24.1.1-jre	HIGH	6.0	6.9	7.0	2.0
6	mysql:mysql-connector-java	8.0.30	MEDIUM	3.1	0.0	7.0	5.0

7	commons-io:commons-io	2.4	LOW	2.5	0.0	7.0	2.0
8	org.apache.commons:commons-lang3	3.4	LOW	2.5	0.0	7.0	2.0
9	org.junit.jupiter:junit-jupiter	5.10.2	LOW	1.7	0.0	5.0	1.0

Score breakdown detail

Dependency	CVE severity	Density bonus	Exposure	Business criticality	Weighted score	Band
log4j-core	10.0 (max 10.0)	+1.5 (3 extra CVEs) → capped 10	8.0	5.0 (billing svc direct import)	8.4	CRITICAL
log4j-api	10.0 (max 10.0)	+0 (1 CVE)	8.0	5.0 (billing svc direct import)	8.4	CRITICAL
jackson-databind (fasterxml)	9.8 (max)	+2.0 (4 extra CVEs) → capped 10	8.0	2.0 (default — no import found)	7.8	HIGH
jackson-databind (fastxml typosquat)	0.0 (unresolvable)	—	7.0	2.0 (default)	2.5 → CRITICAL override	CRITICAL
guava	5.9 (max)	+1.0 (2 extra CVEs)	7.0	2.0 (default — no import found)	6.0	HIGH
mysql-connector-java	0.0	—	7.0	5.0 (DB connector in invoice svc)	3.1	MEDIUM
commons-io	0.0	—	7.0	2.0 (default)	2.5	LOW
commons-lang3	0.0	—	7.0	2.0 (default)	2.5	LOW
junit-jupiter	0.0	—	5.0 (test scope)	1.0 (test tooling)	1.7	LOW

Priority recommendations

P0 — Immediate action required (block release)

- REMOVE** `com.fastxml.jackson.core:jackson-databind:2.9.8` (typosquatted supply-chain risk). Delete from `pom.xml` before the next build. The real dependency `com.fasterxml.jackson.core:jackson-databind` is already declared separately.
- Upgrade** `org.apache.logging.log4j:log4j-core` and `log4j-api` from 2.14.1 to 2.17.1. Log4Shell (CVE-2021-44228, CVSS 10.0) is trivially exploitable via any user-controlled input that reaches a log statement — confirmed present in `DiscountCalculator.java`.

3. **Upgrade** `com.fasterxml.jackson.core:jackson-databind` from `2.9.8` to `2.13.4.2` (minimum safe version). Five CVEs including two CRITICAL RCE deserialization gadget chains.

P1 — Fix within current sprint

4. **Upgrade** `com.google.guava:guava` from `24.1.1-jre` to `32.0.0-jre`. Three CVEs (DoS, local info disclosure). Review API deprecation/breakage before merging.

P2 — Fix within next sprint

5. **Resolve GPL-2.0 license violation** for `mysql:mysql-connector-java:8.0.30`. Evaluate replacing with `com.mysql:mysql-connector-j` (GPL-2.0 + FOSS exception) or an alternative JDBC driver. Obtain legal sign-off if GPL remains.

P3 — Routine maintenance

6. Upgrade `commons-io:commons-io` `2.4` → `2.18.0`.
7. Upgrade `org.apache.commons:commons-lang3` `3.4` → `3.17.0`.

P4 — Housekeeping

8. Upgrade `org.junit.jupiter:junit-jupiter` `5.10.2` → `5.13.0` (test scope only; no blast radius).

CRITICAL — Untrusted HTTP repository. `http://insecure-mirror.example.net/maven2` must be removed from `pom.xml` repositories. Plain-HTTP Maven repositories enable artifact-injection attacks; TLS is mandatory for all artifact sources.

Machine-readable source: `depscan-risk-report.json` (SHA: `61ed8c3140d76e3a19a88954e834d39c9f7635fb`).
Generated by the Dependency & Supply-Chain Plugin — Stage 2. Ready for Auto-Remediation Skill (Stage 3) and PR Validation Agent (Stage 4).